

Security+ 1.2 · The CIA Triad

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.2 — The CIA Triad (5:17)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: 3 objetivos: CONFIDENCIALIDADE (só quem deve, vê — encriptação, ACL, MFA, classificação); INTEGRIDADE (dado não é alterado indevidamente — hash, assinatura digital, certificado); DISPONIBILIDADE (serviço up — redundância, failover, patch, backup). Todo controle serve a pelo menos 1 dos 3.

💡 Highlights que a prova cobra

- C ferida: leak/escuta. I ferida: alterado/fraudado. A ferida: serviço down.
- Hash dá I, NÃO C (não cifrar conteúdo)
- Assinatura digital dá I + autenticação + non-repudiation (o 3-em-1)
- AES = confidencialidade; RSA = troca de chave + assinatura
- 'which of the three goals was COMPROMISED' = a pergunta clássica

🎯 Dicas de prova & Cenários Típicos

- Cenário 'alguém viu o dado'=C · 'alguém alterou'=I · 'não consigo acessar'=A
- Cuidado: 'email enviado por personagem não-autorizado' pode ser I (integridade do remetente) ou C se o conteúdo vazou

Cenário clássico de exame: Cenário típico: 'e-mail com anexo que substitui a ordem de pagamento' = Integridade; 'acesso não autorizado ao dado do paciente' = Confidencialidade; 'site fora do ar no Black Friday' = Disponibilidade.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 1.2 — The CIA Triad)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **IPSEC:** Internet Protocol Security: Suíte de protocolos para comunicação segura na camada de rede (L3), composta por AH (integridade), ESP (cifragem) e IKE (troca de chaves).

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Um atacante intercepta e Lê uma comunicação confidencial entre dois sistemas sem autorização. Que objetivo da tríade CIA foi diretamente comprometido?

- A)** Integridade
- B)** Confidencialidade
- C)** Disponibilidade
- D)** Não-repúdio

2. Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original não ordenou. Que objetivo da tríade foi comprometido?

- A)** Confidencialidade
- B)** Integridade
- C)** Disponibilidade
- D)** Autenticação

3. Um servidor web de e-commerce fica completamente inacessível devido a um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?

- A)** Confidencialidade
- B)** Integridade
- C)** Disponibilidade
- D)** Autenticidade

4. O que uma função HASH criptográfica (como SHA-256) oferece e o que ela NÃO oferece?

- A)** Oferece integridade; NÃO dá confidencialidade (não cifra)
- B)** Oferece confidencialidade; NÃO dá integridade
- C)** Oferece disponibilidade; NÃO dá integridade
- D)** Oferece as 3 ao mesmo tempo

5. Qual controle criptográfico oferece simultaneamente: integridade do dado + autenticação do autor + não-repúdio (non-repudiation)?

- A)** Hash SHA-256 puro
- B)** Criptografia AES simétrica
- C)** Assinatura digital com chave privada
- D)** Backup offline em fita

6. Dados confidenciais estão sendo transmitidos entre um usuário remoto e o servidor corporativo pela internet. Qual estado do dado e proteção correspondente?

- A)** At rest — criptografia de disco BitLocker
- B)** In transit — túnel TLS / VPN IPsec
- C)** In use — enclaves seguros de CPU
- D)** Rest / transit / use — todas indistintas

7. Uma empresa financeira precisa garantir perante auditoria judicial que um gerente não possa negar ter autorizado uma transferência bancária. Qual garantia técnica é exigida?

- A)** Criptografia AES
- B)** Não-repúdio (non-repudiation) via assinatura digital
- C)** Cluster de alta disponibilidade
- D)** Hash MD5 da mensagem

8. Uma aplicação web armazena senhas no banco de dados utilizando hash com salt (ex: bcrypt). Qual objetivo primordial da tríade isso protege e por quê?

- A)** Disponibilidade — agiliza o backup
- B)** Integridade — garante que o arquivo não corrompa
- C)** Confidencialidade — mesmo com vazamento do banco, invasores não leem as senhas claras
- D)** Autenticação — prova a identidade do usuário

9. CENÁRIO: Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?

- A)** Confidencialidade
- B)** Integridade
- C)** Disponibilidade
- D)** Não-repúdio

10. CENÁRIO: Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:

- A) Confidencialidade
- B) Integridade
- C) Disponibilidade
- D) Não-repúdio

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Confidencialidade.

Confidencialidade ('só quem pode, vê'): a leitura indevida por terceiro quebra o sigilo da informação.

2) B — Integridade.

Integridade: o dado foi adulterado no trajeto, deixando de ser exato e confiável.

3) C — Disponibilidade.

Disponibilidade: o serviço caiu e os clientes legítimos não conseguem acessar o sistema.

4) A — Oferece integridade; NÃO dá confidencialidade (não cifra).

Hash é unidirecional: gera uma impressão digital única para checar se o dado mudou (integridade), mas não esconde nem cifra o conteúdo.

5) C — Assinatura digital com chave privada.

A assinatura digital cifra o hash com a chave privada do remetente, garantindo integridade + autenticidade + não-repúdio.

6) B — In transit — túnel TLS / VPN IPsec.

Dado em trânsito (in transit) trafega pela rede e deve ser protegido com TLS ou VPN.

7) B — Não-repúdio (non-repudiation) via assinatura digital.

Não-repúdio: impede que o autor negue a autoria da transação, pois apenas a sua chave privada exclusiva pôde gerar a assinatura.

8) C — Confidencialidade — mesmo com vazamento do banco, invasores não leem as senhas claras.

Confidencialidade: o hash com salt garante que o segredo (a senha) não seja revelado mesmo se a tabela for roubada.

9) B — Integridade.

Integridade: a modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo.

10) C — Disponibilidade.

Disponibilidade: no-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções.

